

[doc. web n. 9990640]
Provision of January 24, 2024
Register of Provisions
n. 39 of January 24, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Pasquale Stazione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, Members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing
Directive 95/46/EC (hereinafter "Code");

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
Resolution of the Guarantor No. 98 of April 4, 2019,
published in G.U. No. 106 of May 8, 2019 and in
www.gpdp.it, doc. web n. 9107633 (hereinafter
"Regulation of the Guarantor No. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Regulation of
the Guarantor No. 1/2000 on the organization and
functioning of the office of the Guarantor for the
protection of personal data, in www.gpdp.it, doc.
web n. 1098801;

REPORTING Dr. Agostino Ghiglia;

PREMISED

1. The investigative activity.

By notes dated XX and XX, the Bambino Gesù Pediatric Hospital, located in Rome, (hereinafter
Pediatric Hospital) notified the Authority, pursuant to Article 33 of the Regulation, of a personal data
breach that occurred between XX and XX, stating that it had received, on XX, at 13:56, a report from a
patient claiming to have accessed (via the dedicated portal "Carta della Salute" <https://>

cartadellasalute.ospedalebambinogesu.it) the report of another patient (...), in addition to having directly detected, at 9:34 on the same day, an anomaly, "promptly reported to the supplier" Dedalus Italia S.p.a., tax code 05994810488, based in Florence, Via di Collodi n. 6/C – postal code 50141 - PEC: dedalus@legalmail.it (hereinafter the Company) - "formally identified as Data Processor by the Hospital (...)". In the aforementioned communications, the Pediatric Hospital also added that "(...) on XX at 12:01, an additional report was received by the Hospital from an interested party, indicating the ability to access a report of another patient. Subsequent analysis revealed a further error, a consequence of the bug already identified and corrected previously, concerning a small number of users."

In describing the breach, the Pediatric Hospital pointed out that it "consisted of the sending, by the system of the supplier Dedalus Italia S.p.A., to the data management system of the Hospital (middleware Mirth) of HL7 laboratory messages containing an information segment reporting a patient identifier different from the content of the message (report). The subsequent propagation of these messages generated an incorrect association between report and patient in other integrated applications. The effect of the aforementioned anomaly is the association of a report, intact and coherent in its entirety, to the wrong patient. The malfunctioning component is the integration component of the Dedalus Dnlab software, of the supplier Dedalus Italia S.p.A. (...).

As a result of the detailed analytical control relating to the individual interested parties and the reports related to them, the number of reports involved that constitute a breach of personal data, putting at risk the rights and freedoms of natural persons, is equal to 24 (reports)."

In addition to describing the systems, software, services, and IT infrastructures involved in the breach, indicating their location, highlighting that the emergence of the bug and its elimination involved the systems provided by the Company, responsible for the processing, the Pediatric Hospital illustrated the technical and organizational measures in place at the time of the breach, as well as those adopted to remedy the breach and reduce the negative effects for the interested parties.

In order to prevent similar breaches in the future, the aforementioned Pediatric Hospital, data controller, has, among other things, requested "the supplier to include an explicit 'non-regression' test for future software developments, in order to avoid that the identified case of computer error (...) may recur in the future."

In relation to what has been represented, the Office, with note dated XX (prot. n. XX), requested further information and clarifications, pursuant to Article 157 of the Code, from the data controller who, with note dated XX (prot. n. XX), provided feedback, stating, among other things, that:

- "(...) no further issues were detected after the date of XX, further reports that could generate a risk to the rights and freedoms of individuals";
- "The measures adopted to remedy the violation of personal data and also to mitigate its possible negative effects have effectively averted the possibility of similar events occurring, as neither the recurrence of the previously resolved bug nor a similar new breach of the system has been highlighted. Furthermore, the actions taken by the Hospital on a definitive basis have allowed for the standardization of even more detailed analysis methods, which are also used for periodic testing and 'sample' analysis, in order to verify the consistency of the systems and the production of reports over time. In any case, it is emphasized that once the report was made to the system Provider, the latter took the necessary corrective actions and the checks carried out, both in the testing environment and in production, confirmed that similar incidents can no longer occur";
- "(...) The event that occurred, in light of what has been illustrated, had effects (...) for a limited period, namely between XX and XX";
- "(...) 6 individuals (the so-called 'Visualized') experienced a loss of confidentiality, as one or more of their reports were exposed to unauthorized persons; 6 individuals (the so-called 'Viewers') accessed reports of other interested parties erroneously, generating a loss of confidentiality; 8 individuals encountered a probable unavailability issue (one of whom was also part of the 'Viewers' group), as the requested report was not available, thus they recorded a malfunction and difficulty in using the service";
- "The Hospital, in order to fully comply with the provisions of Article 34 of the GDPR, has prepared and communicated the violation to the interested parties by post without undue delay, sending two types of

communications by XX” and “(...) has also taken, as an additional measure, to contact the Viewer subjects by telephone in the aforementioned cancellation activity, through a multidisciplinary team established to provide support, where requested, also from an IT perspective to the interested parties”; - “(...) no further reports have been received from the interested parties up to the present date.” The data controller has also attached the appointment documents of the Company as data processor, relating to the service contracts entered into with the latter. In light of the above, with a note dated XX (prot. n. XX), the Office requested information, pursuant to Article 157 of the Code, from the Company, the data processor, which, with a note dated XX, responded to the Authority stating, among other things: “Regarding ‘the detailed description of the bug,’ it concerned the DNLAB solution (‘DNLAB’), provided by the Company to the Bambin Gesù Pediatric Hospital (‘OPBG’), and consisted of sending to the data management system of the same OPBG, namely the middleware Mirth, HL7 laboratory messages containing an information segment reporting a patient identifier different from the content of the message, i.e., the report of the analyses. The subsequent propagation of these messages generated an incorrect association between the report and the patient in the other integrated applications. The problem was related to an error in the custom code of the integration, which manifested itself due to an overlap of the incremental counters of the ‘Seqreferti’ and ‘Seqrichiesta’ tables. The graph in Fig. 1 shows the historical trend of these two values, whose overlap occurred on June 9 of this year.” The Company then illustrated, also through some graphs (“Historical trend of the assignment of values to the sequences ‘Seqreferti’ and ‘Seqrichiesta’; Comparison of the values ‘Seqreferti’ and ‘Seqrichiesta’ between 8:04:23 and 8:06:53 on June 9 of this year”) the technical aspects of the dynamics of the bug determination, and stated that “with regard to DNLAB, the carrying out of periodic vulnerability assessment tests was not and is not contractually provided for.” Moreover, beyond the absence of a contractual obligation in this sense, the Company would not have been able to autonomously carry out such vulnerability assessment activities, as DNLAB resides entirely on the production environment of OPBG.”

2. Assessments of the Department on the processing carried out and notification of the breach pursuant to Article 166, paragraph 5, of the Code

Based on the above representation, this Office - with act dated XX (prot. XX), which must be understood as reproduced here - has notified the Company, as the data processor, of a breach pursuant to Article 166, paragraph 5, of the Code as it was found that 24 reports were subject to a malfunction of the system - in terms of loss of confidentiality and unavailability - due to a bug that occurred in the DNLAB solution (“DNLAB”) provided by the Company - data processor - to the pediatric hospital, which resulted in the processing of personal data carried out in violation of Article 5, paragraph 1, letter f), 9, and 32 of the Regulation. With a note sent on XX, the Company submitted its defensive memoranda in which it highlighted, among other things, that: “regarding the charges made in the Notification against the Company, consisting of the alleged failure by the Company to implement security measures, reference is made to what the Company specified in its previous note of May 15 of this year, namely that: regarding DNLAB, it was and is not contractually provided for between the Company and OPBG.

periodic vulnerability assessment tests; (...) beyond the absence of a contractual obligation in this regard, the Company would not have been able to independently carry out such vulnerability assessment activities, as DNLAB resides entirely on the production environment of OPBG. These arguments, (...) demonstrate how no infringement of the obligations set forth in Article 32 of the Regulation, and therefore of the principle established in Article 5, paragraph 1, letter f) of the Regulation itself, can be attributed to the Company, which found itself in a situation of impossibility, not only legal but also, and above all, material, to independently implement vulnerability assessment activities on the System aimed at preventing and/or mitigating the risk of Data Breach. Such measures could only be legally and materially implemented by OPBG, so the Company cannot be held responsible for an omission regarding the alleged failure to implement security measures that do not fall within the scope of responsibility and control of the Company itself. In light of the above, it is believed that the Company has not violated the provisions of the Regulation”;

“The Data Breach resulted from an accidental event, the severity of which was limited in light of the

interventions carried out by OPBG and – as far as within its own competence – by the Company. It had a limited duration and, regarding the number of affected individuals involved, which is only a few units, it is extremely limited compared to the number of patients managed by OPBG. The alleged violation is, if applicable, at most of a negligent nature, as it indeed stems from an accidental event”;

“(…) Since the detection of the Data Breach, Dedalus has provided the utmost cooperation to remedy the event itself and mitigate its possible negative effects (…) Following the communication of the Data Breach by OPBG, Dedalus activated all measures concerning its area of competence and, in particular, following the isolation of the bug identified in the System, promptly proceeded to analyze it and remove it as of date XX. These actions are also suitable to prevent the recurrence of similar incidents in the future”;

“There are no specific corrective measures already adopted by this esteemed Authority concerning the specific violation contested”;

“(…) as a result of (…) the (data breach), due to unfortunate and entirely episodic circumstances, the Company did not achieve any benefits, nor did it avoid losses as a result thereof.” The Company has, finally, requested to archive the proceeding in question or, in the alternative, to apply a less severe sanction, such as a warning, in place of a monetary penalty.

3. Outcome of the investigative activity

Having noted what is represented in the documentation on record, it is observed that:

- “health data” refers to “personal data related to the physical or mental health of a natural person, including the provision of health care, which reveals information about their health status” (Article 4, paragraph 1, n. 15 of the Regulation). Personal data related to health merit greater protection since the context of their processing could create significant risks to fundamental rights and freedoms (Recital n. 51);
- pursuant to Article 28 of the Regulation, the data controller may entrust processing to third parties that provide sufficient guarantees regarding the implementation of appropriate technical and organizational measures to ensure that the processing is in compliance with data protection legislation (“data processors”). In this case, it appears from the records that the pediatric hospital, as the data controller, avails itself of the services offered by the Company as a data processor;
- the data protection legislation establishes that such data must be “processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage (principle of ‘integrity and confidentiality’)” (Article 5, paragraph 1, letter f) of the Regulation);
- the data controller and, along with it, the data processor, are required to implement “appropriate technical and organizational measures to ensure a level of security appropriate to the risk” taking into account, among other things, “the nature, scope, context and purposes of the processing, as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons” (Article 32, paragraph 1, of the Regulation);
- in particular, the data controller and the data processor implement technical and organizational measures that include, among others, where applicable, (...) the ability to ensure on a continuous basis the confidentiality, integrity, availability, and resilience of processing systems and services (and (...) a procedure to regularly test, verify and evaluate the effectiveness (...) (of such measures) in order to ensure the security of processing” (Article 32, paragraph 1, letters b) and d));
- with regard specifically to the healthcare sector, it is highlighted that the data protection legislation provides that information about health status may only be communicated to the data subject and may be communicated to third parties only on the basis of an appropriate legal basis or at the request of the data subject itself, preceded by a written delegation from the latter (Article 9 of the Regulation);
- the bug operating in the “Dnlab” solution provided by Dedalus S.p.a., as the data processor, resulted in the sending, to the system of

****Data Management of the Data Controller****

The management of data by the data controller, regarding HL7 messages from the laboratory containing an information segment reporting a patient identifier different from the content of the report,

has resulted in the accessibility of reports for 6 patients to unauthorized individuals and the unavailability of their own reports for 8 patients;

- With reference to the defensive argument stating that the functionality of the aforementioned "Dnlab" solution provided by the Company to the Pediatric Hospital "resides entirely in the production environment of OPBG," it is noted that precisely because of the interconnected function of this program with the data management system of the Hospital (middleware Mirth), the Company, in light of the security obligations mentioned above, which also burden the data processor, as well as the technical competence of the latter - due to which the Pediatric Hospital intended to resort to it pursuant to Article 28 of the Regulation - should have foreseen, taking into account, among other things, "the nature, object, context, and purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons" (Article 32, paragraph 1, of the Regulation) adequate security measures and their implementation, including the related periodic checks of such measures, Article 32, paragraph 1, letters b) and d) of the Regulation, to ensure on a permanent basis the confidentiality, integrity, availability, and resilience of the systems. In this sense, Article 28 of the Regulation establishes that the act governing the relationship between the data controller and the processor must provide that the processor adopts all measures required pursuant to Article 32 of the same Regulation (cf. Appointment Act of the data processor, between the Pediatric Hospital and the Company, dated XX, prot. XX, paragraph 3 – "Prescriptions for the Processor," letters d) and f));

- Furthermore, it is considered that the incident occurred between XX and XX and, therefore, within a limited time frame; no complaints or reports have been submitted to the Authority, and from what has been stated by the data controller, no "further consequences for the data subjects have emerged, and the unlawfully viewed data have not been used for other purposes or disseminated, nor is there evidence of significant repercussions resulting in physical, material, or immaterial damage to the data subjects"; regarding the incident, no malicious behavior emerges; the processor acted promptly to mitigate the effects of the violation and in resolving the problem.

****4. Conclusions.****

In light of the evaluations mentioned above, taking into account the statements made by the Company during the investigation - and considering that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor" - the elements provided by the data processor in the defensive memoranda do not allow for overcoming the objections notified by the Office with the initiation act of the proceeding, nor do any of the cases provided for by Article 11 of the Guarantor Regulation no. 1/2019 apply.

For these reasons, the Company, as the data processor, with reference to the "integration component of the Dedalus Dnlab software" provided to the Pediatric Hospital - from which the bug originated - not having foreseen adequate security measures and their implementation, including the related periodic checks, has carried out a processing of personal data:

- in a manner not compliant with the principle of "integrity and confidentiality" in violation of Article 5, paragraph 1, letter f), of the Regulation;
- failing to implement technical and organizational measures suitable to ensure a level of security appropriate to the risk, capable of ensuring the ability to guarantee on a permanent basis the confidentiality, integrity, availability, and resilience of the systems and processing services, as well as a procedure to test, verify, and regularly evaluate the effectiveness of such measures in order to ensure the security of processing (Article 32, paragraph 1, letters b) and d));
- resulting in the communication of health data of 6 patients to six unauthorized third parties, in the absence of an appropriate legal basis and, therefore, in violation of Article 9 of the Regulation.

In this context, considering that measures have been adopted to overcome the vulnerability described above and that requests have been made to the recipients of the reports, subject to violation, for the destruction of such reports, the conditions for the adoption of corrective measures referred to in Article

58, paragraph 2, of the Regulation do not exist.

****5.** Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).******

The violation of Articles 5, paragraph 1, letter f), 9, and 32 of the Regulation is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 4 and 5, of the Regulation.

Considering that the violation of the aforementioned rules occurred as a result of a single conduct, Article 83, paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Considering that, in this specific case, the most serious violation concerns the non-compliance with Article 9 of the Regulation, subject to the administrative sanction provided for by Article 83, paragraph 5, of the Regulation, the total amount of the sanction is to be quantified up to €20,000,000 or, for companies, up to 4% of the total annual worldwide turnover of the previous financial year, if higher.

It should be noted that the Authority, pursuant to Articles 58, paragraph 2, letter i), and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, indicated in Article 83, paragraph 1, of the Regulation in light of the elements provided for in Article 83, paragraph 2, of the Regulation.

In light of the above, in order to assess the severity of the violation (Article 83, paragraph 2, letters a), b), g)), particular consideration is given to the category of personal data processed (related to health), the duration of the violation (4 days), the number of affected individuals (n. 6 regarding the communication of data and n. 8 regarding the loss of availability of personal data), the absence of intent, and the absence of complaints regarding any damages suffered by the affected individuals; in light of this, it is believed that the level of severity of the violation committed by the Company is medium (cf. European Data Protection Board, "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" of May 23, 2023, point 60).

It is also considered, pursuant to Article 83, paragraph 2, of the Regulation that the Authority became aware of the event following the notification of the violation by the Pediatric Hospital (Article 83, paragraph 2, letter h), of the Regulation) and that the responsible party has undergone a previous proceeding concerning a relevant violation (cf. provision of March 23, 2023, n. 86, web document n. 9883731) (Article 83, paragraph 2, letter e) of the Regulation).

By reason of the aforementioned elements, evaluated as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction provided for by Article 83, paragraph 5, letter a), of the Regulation, in the amount of €8,000.00 (eight thousand) for the violation of Articles 5, paragraph 1, letter f), 9, and 32 of the Regulation, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and deterrent.

It is also believed that the accessory sanction of publication on the Authority's website of this provision, as provided for by Article 166, paragraph 7, of the Code and Article 16 of the Regulation of the Authority No. 1/2019, should be applied, also considering the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by Dedalus Italia S.p.a., tax code 05994810488, based in Florence, Via di Collodi n. 6/C, for the violation of Articles 5, paragraph 1, letter f), 9, and 32 of the Regulation as stated in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i), and 83 of the Regulation, as well as Article 166 of the Code, Dedalus Italia S.p.a. to pay the sum of €8,000.00 (eight thousand) as an administrative pecuniary sanction for the violations indicated in this provision; it is represented that the violator, pursuant to Article 166, paragraph 8, of the Code, has the option to resolve the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

COMMANDS

Dedalus Italia S.p.a. in case of failure to resolve the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €8,000.00 (eight thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent executive acts in accordance with Article 27 of Law No. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Authority's website and the annotation of this provision in the internal register of the Authority, as provided for by Article 57, paragraph 1, letter u), of the Regulation, of the violations and the measures adopted in accordance with Article 58, paragraph 2, of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, January 24, 2024

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Ghiglia

THE SECRETARY GENERAL

Mattei